

SİBER GÜVENLİK

WEB UYGULAMALARI VE GÜVENLİK

MOBİL UYGULAMALARI VE GÜVENLİK

WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamaları

internet geliştirildikten sonra web sitelerine ihtiyaç duyuldu. Eskiden bir web sitesi oluşturmak zordu.

Web uygulaması geliştirmeyi eğitimli kişiler dışında bilenler yoktu. Günümüze gelindiğinde bir web uygulaması geliştirmek artık daha da kolaylaştı.



WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarının Geliştirilmesi

Web uygulaması geliştirme kronolojisine baktığımız zaman, eskiden çok az topluluk tarafından web uygulamaları geliştirme, günümüze geldiğimiz zaman ise birçok kişi tarafından geliştirilmeye başlandı.

.



WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler

Güvenlik açıklan kapatılamadığı zaman ilerleyen zamanlarda bu açıklar, hem uygulamayı geliştiren kişiye hem de uygulamayı kullanan kişilere maddi ve manevi olarak büyük zararlar vermektedir.

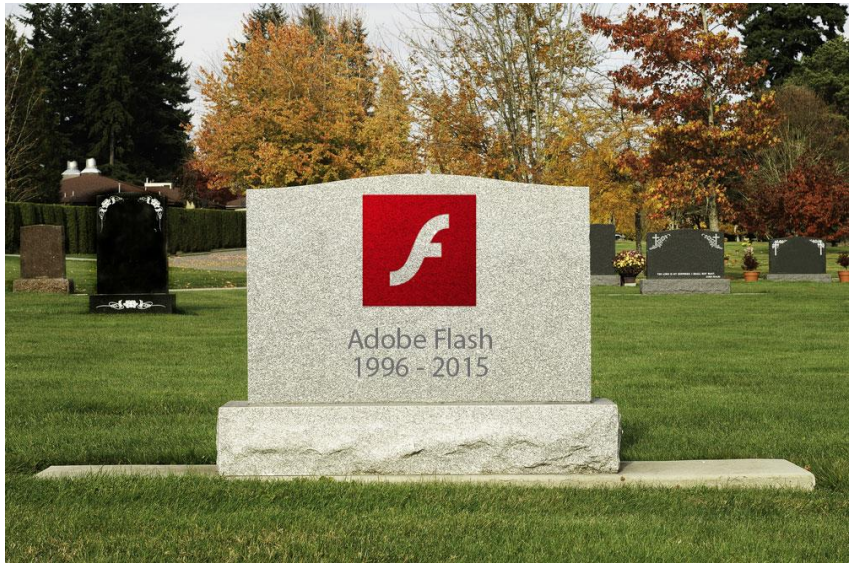


WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler

Eski veya yeni fark etmeden, günümüze kadar geliştirilen web uygulamalarında mutlaka açıklar bulunmaktadır. Bilgisayar ortamında güvenlik açığı olmadan bir uygulama geliştirmek henüz mümkün olmamıştır.

Bir zamanlar Web Sitelerinde popüler olan **Flash** uygulaması veya Flash tabanlı web siteleri. **Flash** uygulamasının güvenlik açıkları ve kaynakları verimsiz kullanışı ayrıca HTML yazılımının gelişmesi ile **12 Ağustos 2012**'de bu uygulamaya destek durdurulmuştur. Günümüzde birçok web tarayıcısının Flash özelliği kapalı olarak gelmektedir.



WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler

Web tabanlı uygulamalar internette veya local bir ağda yayınlanmadan önce mutlaka oluşabilecek hatalara karşı analiz edilmeli ve test sürecinden geçmelidir.

Gerekirse test aşamasında Alfa veya Beta sürümleri yayınlanabilir.

Google'ın **gmail**, mail uygulamasının yıllarca beta sürümünde kalmasının nedenlerinden biri uygulamayı kullanan kişilerin tamamlanmamış beta yazılımın çıkabilecek sorunları kabul ederek kullanması gibi...



WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler

Web tabanlı olan uygulama ve web sitelerinde yazılımlar hiçbir zaman tamamen güvenli denilemez ne kadar güvenlik üst seviyelere getirilse de her zaman bir güvenlik açığı oluşacaktır.

Bu durumun asıl nedeni yazılımların ve yazılım standartlarının sürekli gelişmesidir.

.

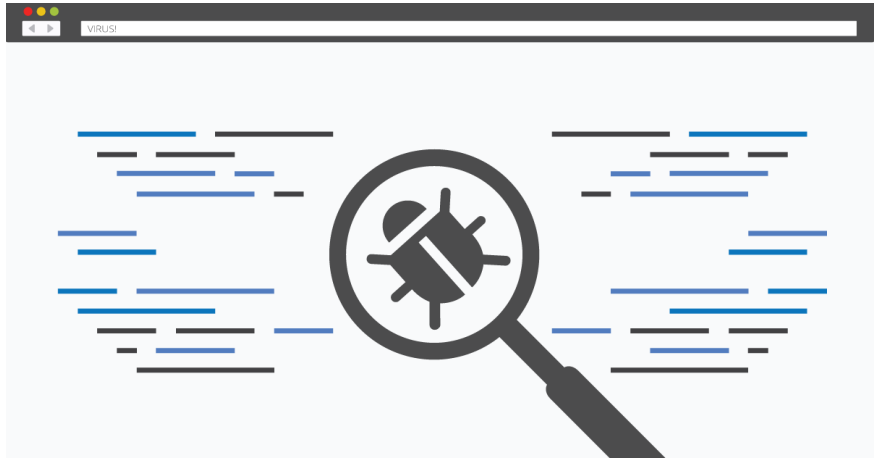


WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler

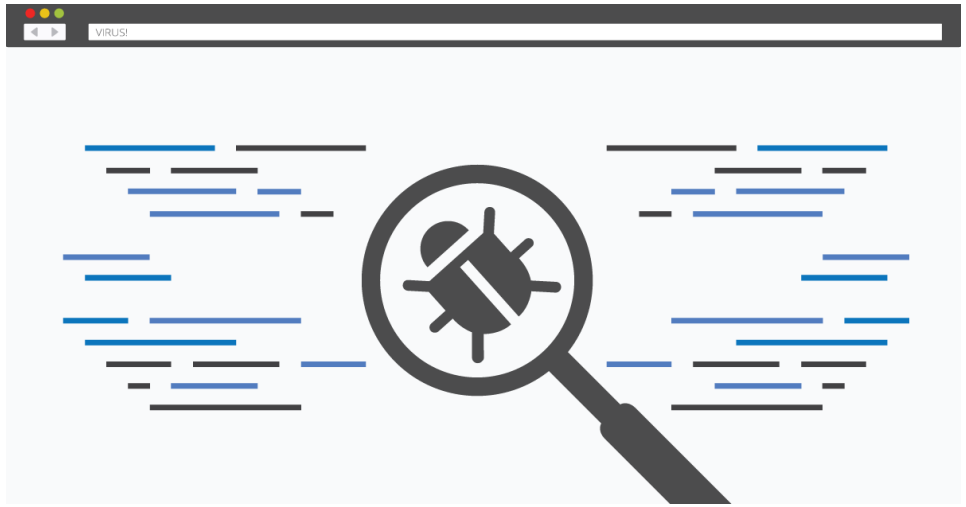
Penetrasyon testlerinde yazılımlarda çeşitli buglar aranır. Sözcük anlamı böcek olan **bug** internet ortamında **sistem zayıflıkları**nı ifade etmektedir.

Büyük web tabanlı projelerde projeyi yazan yazılımcılar ve test yazılımcıları olarak ikiye ayrılır. Software Developer ve Test Developer olarak.



WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler



Bug Researcher'lar ikiye ayrılmaktadır.

- İyi niyetli olanlar
- Kötü niyetli olanlar

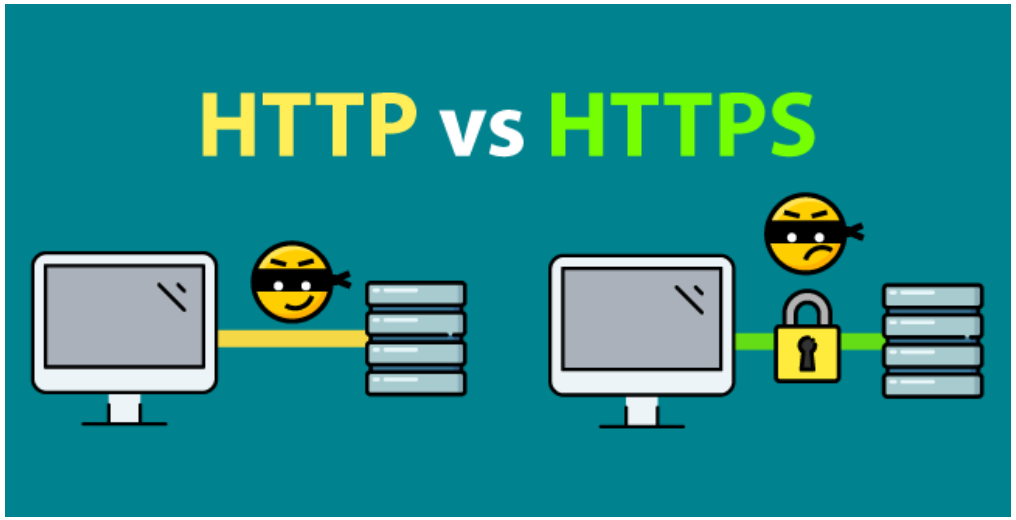
Beyaz şapkalı ve siyah şapkalı hackerlar'da diyebiliriz.

Kötü niyetli bug researcher'lar ilk olarak sistemlerdeki en çok bilinen hataları bulmayı hedefler. Bilinen hatalar ile sistemi sabote etmek veya sistem açıklarını kullanmak çok daha kolaydır. Yeni bulunan bir açığın kullanımı hackerlar için zaman alabilir. **Örnek:** Meltdown ve Spectre

WEB UYGULAMALARI VE GÜVENLİK

Güvenlik Açıklarına Müdahale ve Önlemler

Web tabanlı yazılım projelerinde ve web sitelerinde alınması gerek en büyük önlemlerden biri **HTTPS, SSL, TLS** gibi güçlü şifreleme algoritmalarını bileşimini destekleyen protokollerden birinin kullanımı.



WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarındaki Önemli Güvenlik Açıkları

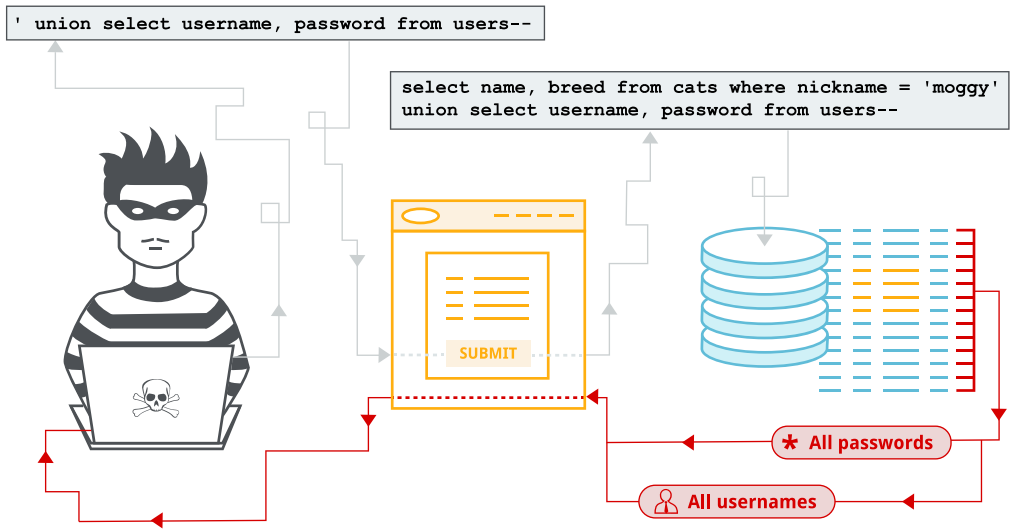
Web uygulamalarındaki önemli ve popüler güvenlik açıkları aşağıdaki gibidir.

- Injection (SQL Injection, XML Injection, CSV Injection, Template Injection, Text Injection, Hyperlink Injection, HTTP Header Injection/HTTP Response Splitting, Command Injection, Code Injection, HTML Injeciton, Meta Tag Injection)
- Cross Site Scripting
- Cross Site Reference Forgery
- Remote File Include
- Hizmet Aksatma Yöntemleri
- Brute Force

WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarındaki Önemli Güvenlik Açıkları

SQL Injection, bir veri tabanı güvenliği açığı olarak bilinmektedir. SQL Injection saldırısı ile yetkisiz olarak veri tabanına sızılabilmektedir. SQL Injection, günümüzde halen yaygın olarak kullanılmakta olup, birçok sitede bulunmaktadır.



WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarındaki Önemli Güvenlik Açıkları

SQL Injection açıkları küçük sitelerden tutun büyük bir firma sitelerine kadar tüm sistemlerde olabilmektedir. SQL Injection açığını hazır sistemlerdede arayabilirsiniz. SQL Injection tam ifadesi Structured Query Language Injectionidur.



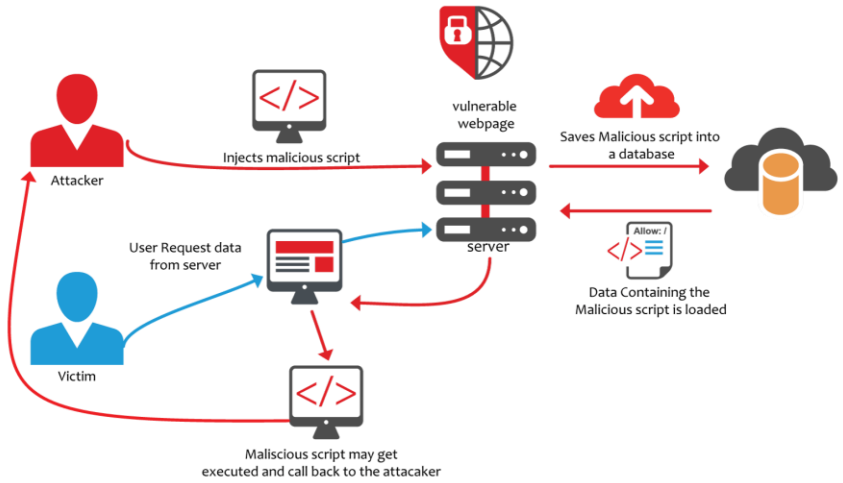
WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarındaki Önemli Güvenlik Açıkları

Cross Site Scripting (XSS); Çapraz Kod Çalıştırma anlamına gelmektedir. Cross site scripting açığı, dinamik web uygulamalarında oluşan bir güvenlik açığıdır.

Geçmişte bu açık yaygın olsa da günümüzde pek fazla yaygın değildir. Ancak bu açık önemli açıklar arasında yer almaktadır.

Cross site scripting açığı, en çok POST ve GET metotlarının kullanılmış olduğu bölümlerde meydana gelmektedir. POST ve GET metotlarının kullanım alanlarına örnek verecek olursak; arama yapma alanları, galeri alanı, yorumlar gibi alanlarda meydana gelebilmektedir.



WEB UYGULAMALARI VE GÜVENLİK

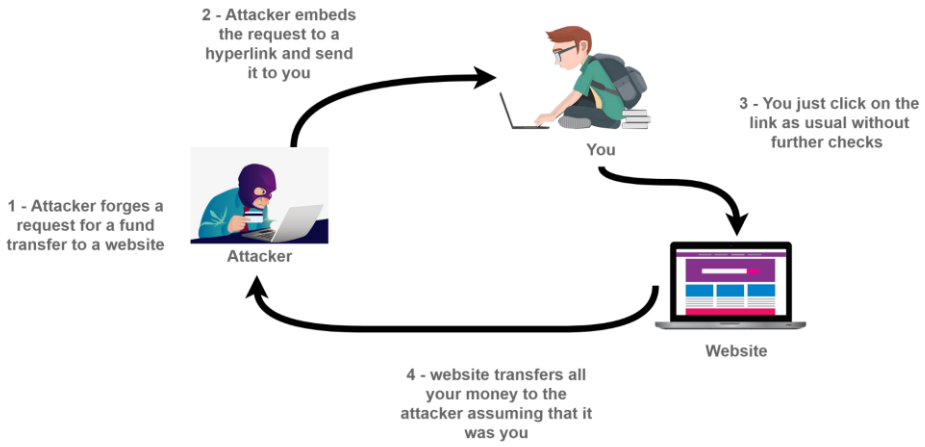
Web Uygulamalarındaki Önemli Güvenlik Açıkları

Cross Site Reference Forgery; diğer güvenlik açıkları gibi web uygulamalarında meydana gelmektedir.

Cross site reference forgery, kısa adı olarak xsrf-csrf olarak da bilinmektedir.

Xsrf saldırıları, siteye entegre kod şeklinde çalışmaktadır. Siteye entegre etme isminin diğer bir adı hostile linking olarak bilinmektedir.

Csrf açıkları güncel **bug listelerinde** ilk sıralarda yer almaktadır. Csrf açıkları web uygulamasının tüm bölümlerinde aranmaktadır. Bu açıkta kullanılan browser en çok **Opera**'dır.



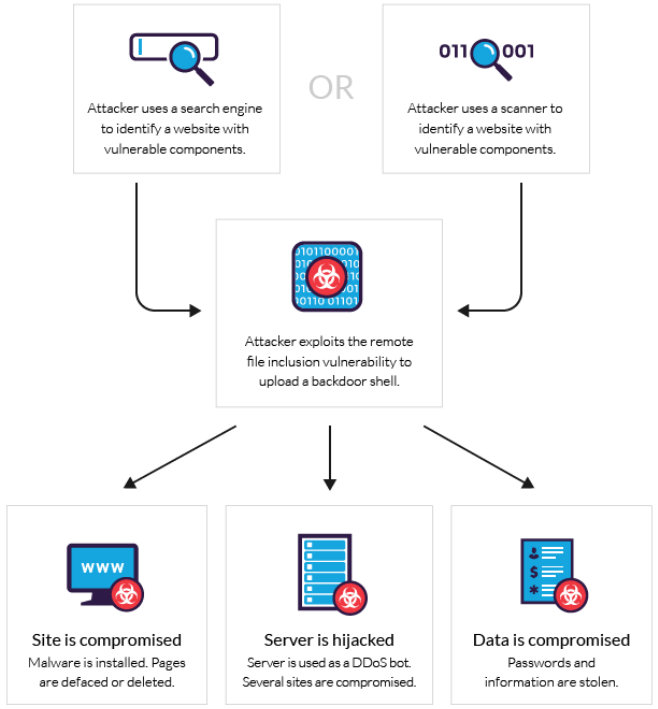
WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarındaki Önemli Güvenlik Açıkları

Remote File Include, uzaktan dosya yükleme anlamına gelmektedir. Uzaktan dosya yükleme, tamamen diğer açıklarda olduğu gibi bu açıkta da izinsiz olarak yapılmaktadır.

Herhangi bir exploit kodu veya bir editör yardımıyla, uzaktan zararlı dosyalar olarak adlandığımız **Shell dosyaları** yüklenerek sisteme sızılabilmektedir.

Remote file include açığı güncel olarak fazla bulunmamaktadır. Ancak henüz olarak tam kapanmıştır diyemeyiz.

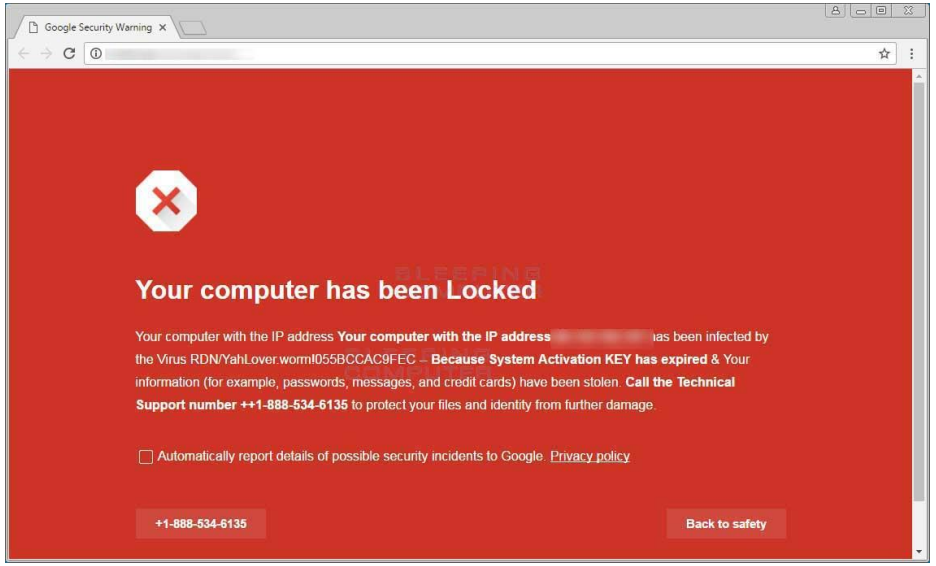


WEB UYGULAMALARI VE GÜVENLİK

Web Uygulamalarındaki Önemli Güvenlik Açıkları

Remote file include açığı güncel olarak fazla bulunmamaktadır. Ancak henüz olarak tam kapanmıştır diyemeyiz.

Remote file include açığı genellikle sitelere Shell yüklemek için kullanılmaktadır. Shell olarak adlandırdığımı zararlı dosyalar sistemde safe mode off yapabilmektedir. izinsiz olarak yüklenen bu dosyalar sayesinde sunucuda yer alan diğer web uygulamalarına da zarar verebilmektedir. Bu açık günümüzde güncel olmasa da herhangi bir hata sonucu sunucuda bulunan tüm siteleri etkileyebilmektedir.



WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri

CMS (Content Management System): İçerik yönetim sistemi bulunan web siteleri, web siteleri üzerinde hızlı bir şekilde dinamik sayfalar, yazılar ve içerikler oluşturmamızı sağlar.

İnternet üzerinde açık kaynak kodlu(Open Source) birçok CMS bulunmaktadır.

Bunlardan en önemlileri;

Wordpress, Joomla, Drupal, Magento ve TYPO3'tür.



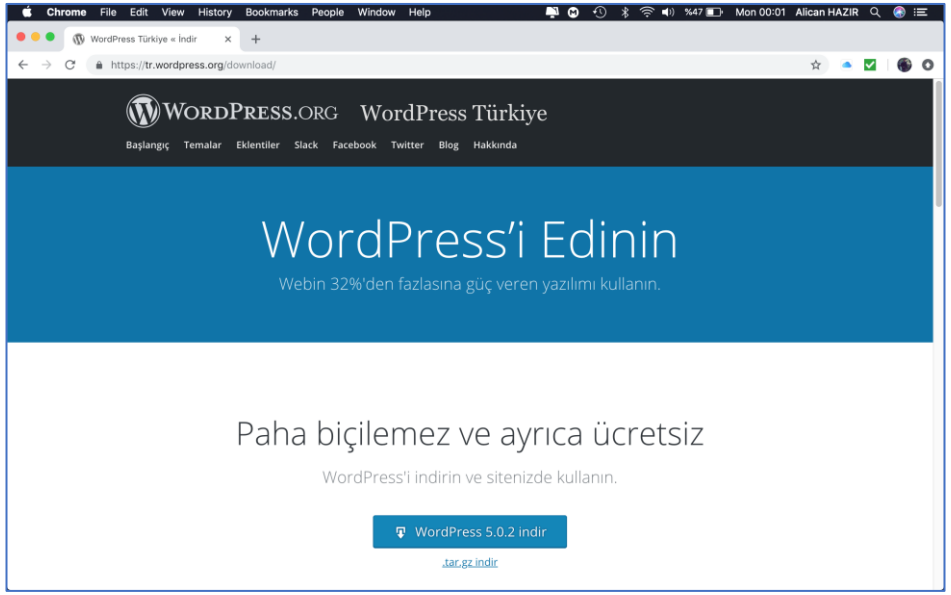
WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri

İnternetin %32'lik bir kısmında açık kaynak kodlu bir yazılım olan Wordpress web siteleri bulunmakta.

Wordpress, web sitelerinde eklentiler yardımıyla bugün neredeyse yapılamayacak hiçbir şey bulunmamakta e-ticaret bile yapılabilmektedir.

İnternetin %32'lik bir kısmını elinde bulunduran bu yazılım aynı zamanda birçok tehlikeyi de beraberinde getirmekte.



WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları

Wordpress web siteleri her ne kadar sürekli güncellense de kullanılan ekstra eklentiler yüzünden diğer sitelere göre güvenlidir veya açığı yoktur diyemeyiz. Açık kaynak kodlu olması yüzünden hackerlar tarafından her zaman hedef olarak gösterilmektedir.

.



WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları - Önlemler!

Burada açık kaynak kodlu yazılımları kullanacak olan yazılımcılar kesinlikle kullanılan yazılımda çıkabilecek açıkları kapatması gereklidir.

Örnek olarak: Wordpress yerine daha az hedef olan Joomla veya Drupal açık kaynak kodlu yazılımlar kullanılabilir veya Wordpress için üretilen yaygın kullanılan eklentiler kullanmak yerine alternatifleri kullanılabilir.



.

WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları - Önlemler!

- Kullanılan sunucu veya hosting yazılımı güncel olmalıdır.
- Kullanılan sunucu ve hostingte çeşitli güvenlik önlemleri alınmalıdır
- Yazılım ve eklentileri güncel olmalıdır.
- Yazılımın sürümleri kapatılmalıdır.(hackerlar hangi sürüm olduğunu görmemeli!)
- .



WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları - Önlemler!

- Veritabanı kullanıcı adı ve şifresi karmaşık olmalıdır.
- FTP tarafında klasör izinleri doğru verilmelidir.
- **.HTACCESS** dosyası güvenli hale getirilmeli
- Güvenlik için özel eklentiler eklenmelidir.
- Çeşitli toollar ile güvenlik taramaları yapılmalıdır.



WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları - Önlemler!

Wordpress yazılımları için çeşitli güvenlik eklentileri.

- WPS Hide Login
- Easy Hide Login
- BulledProof Security Pro
- Wordfence Security
- iThemes Security
- Acunetix WP Security
- All In One WP Security & Firewall



WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları - Önlemler!

Ayrıca; theme klasöründeki function.php dosyasına **remove_action('wp_head' , 'wp_generator');** kodu yazılarak Wordpress sürümü gizlenebilir.



Wordpress için Dosya ve Klasör İzinleri

wp-includes/:755

wp-admin/:755

wp-admin/js/:755

wp-content/themes/:755

wp-content/plugins/:755

wp-admin/index.php: 644

wp-config.php: 644

.htaccess: 644

WEB UYGULAMALARI VE GÜVENLİK

CMS Web Siteleri Açıkları - Önlemler!

Wordpress için çeşitli Toollar

- https://sitecheck.sucuri.net
- https://www.siteguarding.com/en/sitecheck
- https://suip.biz
- https://hackertarget.com/wordpress-security-scan

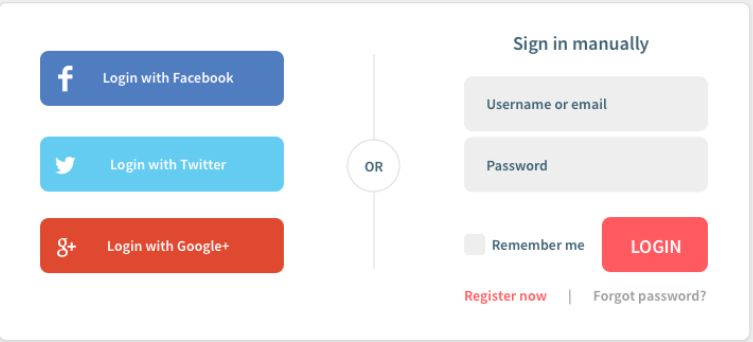


WEB UYGULAMALARI VE GÜVENLİK

Sosyal Medya Web Uygulamaları İzinler

Web uygulamalarında karşılaşılan en önemli güvenlik açıklarından biride **"social media authentication"**

Social Media Authentication: Sosyal medya hesaplarımız veya popüler mail uygulamaları iyi **yahoo gmail** hesapları gibi hesaplar ile bir siteye, foruma veya herhangi bir uygulama ile otomatik bir şekilde üye olma.

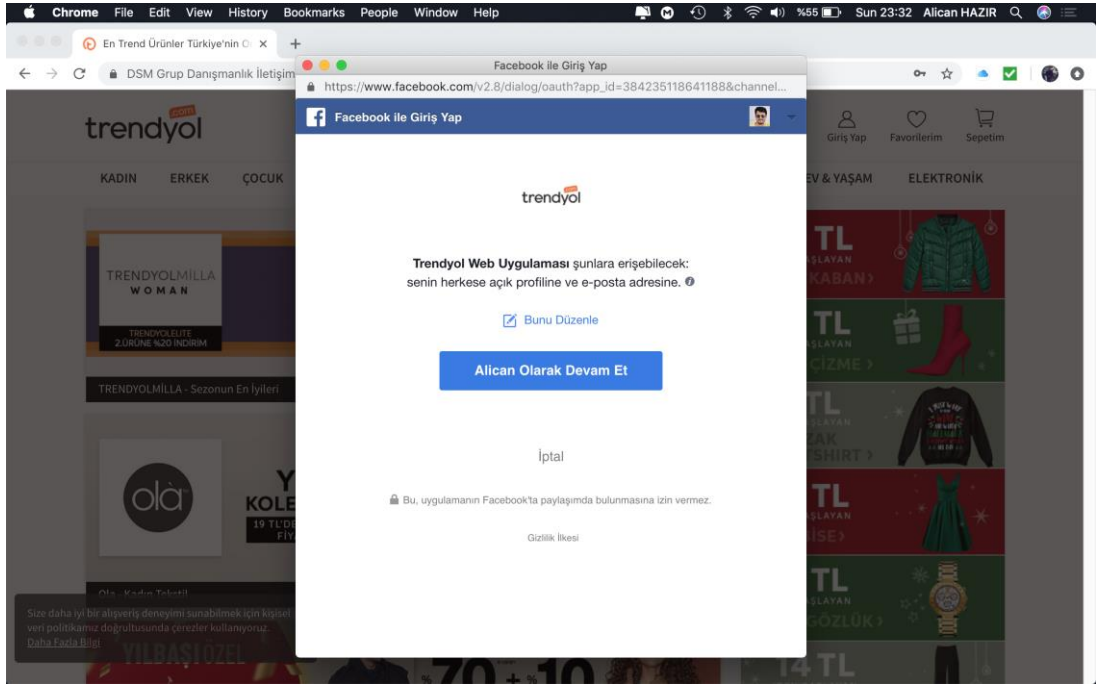


WEB UYGULAMALARI VE GÜVENLİK

Sosyal Medya Web Uygulamaları İzinler

Görselde güvenilir bir e-ticaret sitesi olan trendyol web sitesinin **facebook hesabınız** ile otomatik üye olma uygulaması gözükmekte.

.



WEB UYGULAMALARI VE GÜVENLİK

Sosyal Medya Web Uygulamaları İzinler

Peki güvenilir olmayan veya bilgileri kötüye kullanan bir sitede herhangi bir sosyal medya hesabımız ile otomatik olarak giriş yapsaydık bizi neler beklerdi.

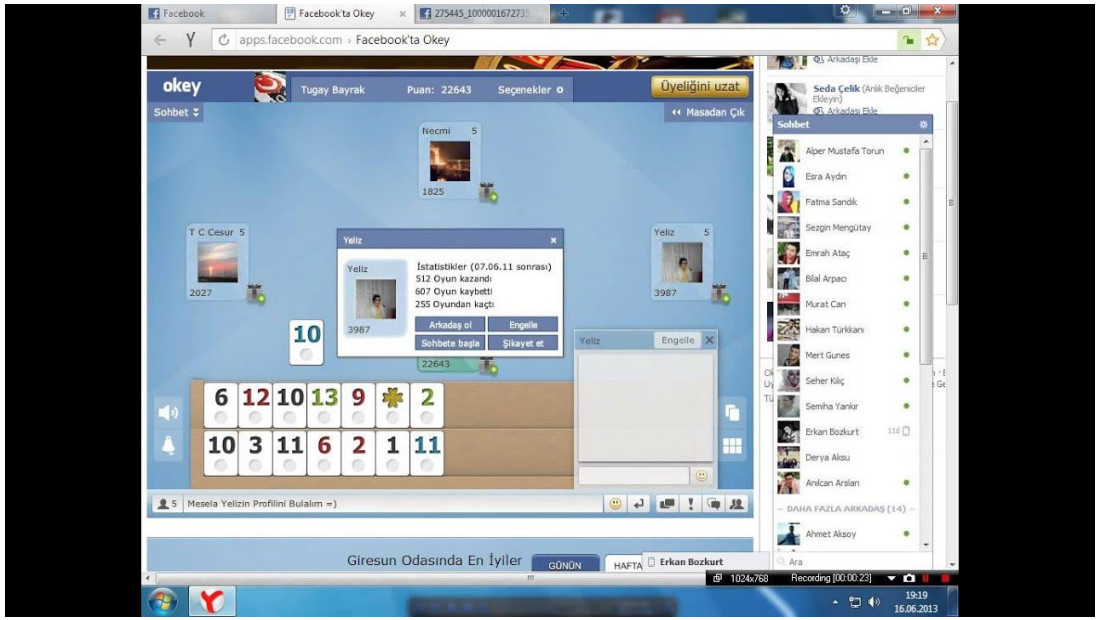
1. Sosyal Medya Hesabımızda adımıza yönelik virüslü paylaşımlar yapılabilir bu paylaşımlardan kişi listemizdekilerde etkilenebilir.
2. Kişi listemize spam mesaj, mail veya fake mailler, reklam mailleri gönderilebilir.
3. Sosyal Medya Hesabımız Hacklenebilir.



WEB UYGULAMALARI VE GÜVENLİK

Sosyal Medya Web Uygulamaları İzinler

Korunma Yolları: Güvenmediğimiz sitelerde sosyal medya hesaplarımız ile üye olma gibi bağlantıları kullanmamak.



MOBİL UYGULAMALARI VE GÜVENLİK

Mobil Uygulamalar ve Güvenlik

Günümüz akıllı telefonlarında kullanılan yazılımlar. Mobil uygulamaların aktif bir şekilde internet kullanması ile birlikte mobil uygulamaların güvenirliği de artmaktadır.



MOBİL UYGULAMALARI VE GÜVENLİK

Mobil Uygulamalar ve Güvenlik

Apple 3. parti uygulama geliştiricilerin uygulamalarında herhangi bir güvenlik zafiyeti gördüğünde uygulamayı marketten kaldırdığı çok sık görülmektedir. **Örnek:** CIA Uygulaması

Ayrıca Android sistemlere çeşitli uygulamalar uygulama marketi dışından da yüklenebilmektedir. Buda en önemli güvenlik zafiyetlerinden biri.

